

Direction des Systèmes Numériques Éducatifs du Primaire (DSNEP)

# Politique de Sécurité des Systèmes d'Information

Volet organisationnel

| Version | Rédacteur              | Autorité<br>d'approbation                | Date d'approbation |
|---------|------------------------|------------------------------------------|--------------------|
| V1.00   | Groupe de Travail PSSI | Comité Stratégique<br>de Sécurité des SI | 15/01/2026         |

Louis AUBERT – Ludivine PERRIER-BABIN – Ulrich  
FOKAM-GOUAYOU – Solange Dominique EYAGA NDEME  
– Jean-Marc AWAD  
15/01/2026

## Table des matières

|                                                             |    |
|-------------------------------------------------------------|----|
| Introduction & contexte .....                               | 3  |
| 1. Périmètre de la PSSI .....                               | 3  |
| 1.1 Périmètre organisationnel.....                          | 3  |
| 1.2 Identification des actifs .....                         | 3  |
| 1.3 Cartographie des actifs .....                           | 4  |
| 1.4 Gouvernance et responsabilités.....                     | 4  |
| 2. Classification de l'information .....                    | 5  |
| 2.1 Typologie des données .....                             | 5  |
| 2.2 Niveaux de classification .....                         | 5  |
| 2.3 Objectifs de sécurité .....                             | 6  |
| 3. Gestion des accès et des identités .....                 | 6  |
| 3.1 Principes directeurs .....                              | 6  |
| 3.2 Attribution et révocation des droits.....               | 7  |
| 3.3 Accès physique.....                                     | 7  |
| 4. Sécurité des postes et des serveurs.....                 | 7  |
| 4.1 Postes de travail .....                                 | 7  |
| 4.2 Serveurs .....                                          | 8  |
| 5. Sécurité des réseaux .....                               | 8  |
| 5.1-Segmentation des réseaux .....                          | 8  |
| 5.2-Routage sécurisé.....                                   | 9  |
| 5.3-Contrôle des accès réseau.....                          | 9  |
| 5.4-Surveillance des communications .....                   | 9  |
| 6. Sécurité applicative.....                                | 9  |
| 6.1-Sécurité intégrée au cycle de vie des applications..... | 9  |
| 6.2-Gestion des mises à jour et correctifs .....            | 10 |
| 6.3- Contrôle des accès applicatifs.....                    | 10 |
| 7. Sauvegarde et résilience .....                           | 10 |
| 7.1 Objectif de la politique de sauvegarde .....            | 10 |
| 7.2 Périmètre des sauvegardes.....                          | 11 |
| 7.3 Principes organisationnels.....                         | 11 |

|                                                      |    |
|------------------------------------------------------|----|
| 7.4 Test et amélioration continue.....               | 11 |
| 8. Journalisation et supervision .....               | 12 |
| 8.1 Objectifs de la journalisation .....             | 12 |
| 8.2 Principes de gouvernance.....                    | 12 |
| 8.3 Exploitation des journaux .....                  | 12 |
| 9. Gestion des incidents de sécurité.....            | 12 |
| 9.1 Objectifs .....                                  | 12 |
| 9.2 Organisation et responsabilités.....             | 13 |
| 9.3 Processus de gestion des incidents.....          | 13 |
| 9.4 Communication et obligation réglementaire .....  | 13 |
| 10. Plan de Continuité & de Reprise d'Activité ..... | 14 |
| 10.1 PCA.....                                        | 14 |
| 10.2 PRA .....                                       | 14 |
| 11. Sensibilisation.....                             | 14 |

## Introduction & contexte

La Ville de Rennes, collectivité territoriale engagée dans la modernisation de ses services publics, déploie une stratégie numérique au service de l'éducation. La Direction des Systèmes Numériques Éducatifs du Primaire (DSNEP) est responsable de la conception, du déploiement, de l'exploitation et de la maintenance des systèmes d'information des établissements scolaires publics de la ville.

Dans un contexte de menaces croissantes sur les infrastructures numériques (ransomware, usurpation de comptes, fuites de données), il est nécessaire de définir une Politique de Sécurité des Systèmes d'Information (PSSI) claire et partagée. La présente PSSI constitue le document de référence en matière de gouvernance de la sécurité des systèmes d'information au sein de la DSNEP. Elle fixe les principes, les objectifs et les responsabilités visant à protéger les actifs informationnels, assurer la continuité du service public éducatif et renforcer la confiance des usagers.

La mise en œuvre de la PSSI s'inscrit dans le cadre réglementaire du RGPD et s'appuie sur les recommandations de l'ANSSI pour les collectivités territoriales, ainsi que sur les bonnes pratiques de management de la sécurité de l'information définies par la norme ISO/IEC 27001. Elle répond à la nécessité de maîtriser les risques liés aux vulnérabilités organisationnelles, techniques et humaines des systèmes d'information éducatifs, susceptibles d'entraîner des atteintes à la confidentialité, à l'intégrité ou à la disponibilité des services.

## 1. Périmètre de la PSSI

### 1.1 Périmètre organisationnel

La présente Politique de Sécurité des Systèmes d'Information s'applique à l'ensemble des systèmes d'information participant aux missions numériques éducatives de la Ville de Rennes. Elle concerne la Direction des Systèmes Numériques Éducatifs du Primaire, incluant les écoles maternelles et élémentaires publiques relevant de la compétence municipale, ainsi que l'ensemble des agents, personnels éducatifs, administratifs et techniques utilisant les services numériques mis à disposition.

La PSSI couvre également les prestataires, partenaires et sous-traitants disposant d'un accès, direct ou indirect, au système d'information, ainsi que les utilisateurs finaux des services numériques éducatifs, notamment les élèves et leurs représentants légaux.

Elle s'applique sur l'ensemble du cycle de vie des systèmes et des actifs informationnels, depuis leur conception et leur déploiement jusqu'à leur exploitation, leur maintenance et leur mise hors service.

### 1.2 Identification des actifs

Dans le cadre de la gestion de la sécurité de l'information, les actifs du système d'information de la DSNE sont identifiés, recensés et régulièrement mis à jour. Cette identification permet de déterminer leur nature, leur criticité et les mesures de protection appropriées.

Les actifs primaires comprennent principalement les données à caractère personnel relatives aux élèves, aux familles et aux personnels, les données pédagogiques, scolaires et administratives, ainsi que la continuité du service public éducatif et des services numériques associés. Ces actifs représentent les enjeux fondamentaux de la sécurité de l'information.

Les actifs supports regroupent l'ensemble des moyens nécessaires au fonctionnement des systèmes d'information, incluant les infrastructures techniques telles que les réseaux, serveurs, postes de travail et équipements mobiles, les applications et services numériques éducatifs, les ressources humaines impliquées dans l'exploitation et l'usage des systèmes, ainsi que les locaux, équipements et moyens physiques associés.

### 1.3 Cartographie des actifs

La cartographie est réalisée sous la responsabilité du Responsable de la Sécurité des Systèmes d'Information, en collaboration avec les responsables métiers et les équipes techniques. Elle est formalisée, documentée et mise à jour de manière régulière, notamment lors de l'introduction de nouveaux services numériques, de changements organisationnels significatifs ou à la suite d'incidents de sécurité.

Les actifs sont regroupés par grandes catégories fonctionnelles, incluant :

- Les services numériques éducatifs (ENT, applications pédagogiques, outils administratifs),
- Les données associées aux missions éducatives, administratives et réglementaires,
- Les infrastructures et environnements techniques supports,
- Les ressources humaines intervenant dans l'exploitation, l'administration ou l'usage des systèmes,
- Les partenaires et prestataires participant au fonctionnement des services numériques.

Chaque actif identifié fait l'objet d'une évaluation de criticité fondée sur les critères de confidentialité, d'intégrité et de disponibilité, ainsi que sur les impacts potentiels en cas d'incident de sécurité. Cette évaluation permet de prioriser les actions de sécurité, d'orienter les décisions de gouvernance et d'assurer une protection cohérente des systèmes d'information au regard des enjeux du service public éducatif.

La cartographie des actifs constitue un référentiel de référence pour l'ensemble des démarches de sécurité de l'information, notamment la classification des données, la gestion des risques, la définition des droits d'accès et le pilotage de la continuité d'activité.

### 1.4 Gouvernance et responsabilités

La gouvernance de la sécurité des systèmes d'information repose sur une répartition claire et formalisée des rôles et responsabilités au sein de la Ville de Rennes.

La Politique de Sécurité des Systèmes d'Information est élaborée par le Groupe de Travail PSSI, instance transverse associant les parties prenantes concernées par la sécurité des systèmes d'information et les usages numériques éducatifs. Ce groupe est chargé de la rédaction, de la mise à jour et de la cohérence de la PSSI avec les orientations stratégiques, réglementaires et opérationnelles de la Ville de Rennes.

L'autorité d'approbation de la présente PSSI est assurée par le Comité Stratégique de Sécurité des Systèmes d'Information, instance décisionnelle placée sous l'autorité de la Direction Générale de la Ville de Rennes. Ce comité valide la PSSI et ses mises à jour, définit les orientations en matière de sécurité des systèmes d'information et veille à l'engagement des directions concernées dans sa mise en œuvre.

La Direction Générale porte la responsabilité globale de la sécurité des systèmes d'information et garantit l'application de la PSSI au sein de l'organisation. Le Responsable de la Sécurité des Systèmes d'Information (RSSI) assure le pilotage de la sécurité de l'information, le suivi des risques, la coordination des actions de sécurité et la gestion des incidents de sécurité majeurs.

Les responsables métiers sont chargés de l'expression des besoins fonctionnels, de la validation des droits d'accès aux systèmes et aux données, ainsi que du respect des règles de sécurité applicables dans leurs périmètres respectifs. Ils contribuent à l'identification des risques et à la mise en œuvre des mesures organisationnelles nécessaires.

Les équipes techniques et administrateurs des systèmes d'information assurent la mise en œuvre opérationnelle des mesures de sécurité, le maintien en condition de sécurité des systèmes, ainsi que l'application des procédures définies par la PSSI. La DSNEP s'appuie aussi sur un centre d'opération de sécurité (SOC), externalisé, qui est chargé de la surveillance continue des événements de sécurité.

Enfin, l'ensemble des utilisateurs est tenu de respecter les règles définies par la PSSI et de signaler sans délai tout incident de sécurité ou comportement suspect.

## 2. Classification de l'information

### 2.1 Typologie des données

Les systèmes d'information de la DSNE traitent différentes catégories de données, incluant des données à caractère personnel et sensibles soumises au RGPD, des données pédagogiques et scolaires, des données relatives aux ressources humaines et aux finances, des données techniques telles que les journaux, configurations et métriques, ainsi que des données contractuelles et réglementaires.

### 2.2 Niveaux de classification

Les informations sont classifiées selon quatre niveaux :

| Niveau | Description     | Impact potentiel |
|--------|-----------------|------------------|
| Public | Diffusion libre | Faible           |

|                 |                      |            |
|-----------------|----------------------|------------|
| <b>Interne</b>  | Usage professionnel  | Modéré     |
| <b>Sensible</b> | Accès restreint      | Élevé      |
| <b>Critique</b> | Protection renforcée | Très élevé |

Chaque niveau correspond à des exigences spécifiques en matière de protection, proportionnées aux impacts potentiels en cas de compromission, qu'ils soient juridiques, organisationnels, financiers ou réputationnels.

Les mesures de sécurité mises en œuvre sont systématiquement adaptées au niveau de classification de l'information concernée.

La classification de l'information est réalisée par le responsable métier propriétaire de la donnée, en lien avec le RSSI pour les actifs sensibles ou critiques. Cette classification est effectuée dès la création ou l'acquisition de l'actif informationnel et fait l'objet d'une révision lors de toute évolution significative de son usage, de sa nature ou de son exposition aux risques.

### 2.3 Objectifs de sécurité

La politique de sécurité vise à garantir :

- La confidentialité, en particulier pour les données concernant des mineurs,
- L'intégrité, afin d'assurer l'exactitude et la fiabilité des informations,
- La disponibilité, condition essentielle à la continuité pédagogique et administrative.

## 3. Gestion des accès et des identités

### 3.1 Principes directeurs

Chaque utilisateur, qu'il s'agisse d'un agent, d'un enseignant ou d'un prestataire, dispose d'un accès adapté à ses missions et limité aux ressources nécessaires. Cette approche permet de réduire les risques de fuite de données ou d'erreur humaine pouvant compromettre la confidentialité ou l'intégrité des informations.

Les rôles et responsabilités sont clairement séparés afin d'éviter qu'une seule personne ait un contrôle complet sur un processus sensible. La création des comptes, l'adaptation des droits lors des changements de poste et la suppression des comptes des collaborateurs quittant l'organisation sont systématiquement consignées.

Pour les systèmes critiques, comme les bases de données des élèves ou les espaces numériques de travail, des mécanismes d'authentification renforcée sont appliqués afin de garantir que seuls les utilisateurs habilités peuvent accéder aux services. Ces règles respectent les standards de sécurité définis par la DSNEP et les obligations légales, notamment celles du RGPD.

Toutes les actions des utilisateurs sont tracées afin de faciliter la réalisation d’audits et la vérification de la conformité aux règles de sécurité. La sensibilisation des utilisateurs est continue, portant sur la gestion sécurisée des identifiants, la vigilance face aux tentatives de phishing et le signalement immédiat de toute activité suspecte.

### 3.2 Attribution et révocation des droits

Les droits d’accès sont attribués selon le modèle des rôles (RBAC) et validés par la hiérarchie. Les responsables métiers définissent les besoins de leurs équipes et s’assurent que chaque accès correspond à une mission réelle, tandis que les administrateurs appliquent ces droits et veillent à leur traçabilité.

Des revues régulières des habilitations sont effectuées pour vérifier que les accès logiques et physiques restent pertinents et pour corriger rapidement toute dérive. Lorsque des changements de poste interviennent ou qu’un utilisateur quitte l’organisation, ses droits sont immédiatement révoqués. Le processus est centralisé dans un système de gestion des identités et des accès, garantissant traçabilité, auditabilité et conformité avec les obligations légales.

### 3.3 Accès physique

L’accès physique aux locaux, infrastructures et équipements critiques est encadré par des règles strictes afin de protéger les systèmes d’information et les données sensibles. Les salles hébergeant des serveurs, des équipements réseau ou des supports de stockage contenant des informations à caractère personnel sont considérées comme des zones à accès restreint.

Seules les personnes habilitées, en fonction de leur rôle et de leurs responsabilités, peuvent pénétrer dans ces zones. Les droits d’accès physique sont alignés avec les droits logiques : toute modification des permissions ou révocation d’un compte utilisateur entraîne la mise à jour correspondante des habilitations physiques.

Tout accès est enregistré et suivi, et des dispositifs de contrôle adaptés aux rôles et responsabilités sont utilisés pour assurer un suivi rigoureux. Les utilisateurs sont informés de leurs obligations lors de l’accès aux zones sensibles, notamment l’interdiction de divulguer des informations, l’utilisation de dispositifs non autorisés ou le stockage non sécurisé de documents. Tout incident ou anomalie constatée est immédiatement signalé au RSSI ou à la personne responsable de la sécurité physique.

Ces mesures permettent de protéger les actifs critiques de la DSNEP contre les intrusions, le vol ou la compromission physique, tout en garantissant la continuité des services éducatifs et le respect des exigences réglementaires liées à la protection des données sensibles.

## 4. Sécurité des postes et des serveurs

### 4.1 Postes de travail

Les postes de travail utilisés par les agents, les enseignants et le personnel éducatif doivent permettre un usage sécurisé des systèmes d’information et des données

traitées par la DSNEP. Leur utilisation s'inscrit dans le respect des règles définies par la présente politique, afin de limiter les risques d'accès non autorisé, de perte de données ou de compromission des informations.

L'accès aux postes de travail est strictement personnel et réservé aux utilisateurs habilités. Chaque utilisateur est responsable de l'usage de son poste et doit veiller à la protection de ses identifiants ainsi qu'au verrouillage de sa session en cas d'absence. L'installation de logiciels et l'utilisation de périphériques externes sont encadrées afin de prévenir l'introduction de menaces ou de logiciels non autorisés.

Des mesures organisationnelles sont mises en place pour encadrer l'administration, la maintenance et le renouvellement des postes de travail. L'état de conformité des postes est suivi afin de s'assurer qu'ils respectent les règles de sécurité en vigueur. En cas d'incident ou de comportement anormal, des procédures définies permettent une prise en charge rapide et adaptée.

Ces dispositions contribuent à la protection des données et à la continuité des activités pédagogiques et administratives, tout en responsabilisant les utilisateurs dans l'usage quotidien des outils numériques.

## 4.2 Serveurs

Les serveurs sont organisés et exploités selon leur criticité et leur rôle dans les services numériques éducatifs. L'accès à ces ressources est encadré par des responsabilités définies et des processus formalisés, garantissant que seuls les personnels habilités peuvent intervenir.

Des procédures organisationnelles de maintenance et de sauvegarde sont établies pour préserver la disponibilité et la fiabilité des services. Des tests réguliers sont réalisés pour vérifier leur efficacité. Ces mesures assurent que les systèmes essentiels restent protégés tout en garantissant la continuité des services pour tous les utilisateurs.

# 5. Sécurité des réseaux

La sécurité réseau repose sur une approche de défense en profondeur visant à réduire la surface d'attaque et à limiter les mouvements latéraux en cas de compromission. Cette stratégie s'articule autour de quatre piliers organisationnels complémentaires

## 5.1-Segmentation des réseaux

Le réseau doit être organisé en zones fonctionnelles distinctes afin d'isoler les usages et de limiter les mouvements latéraux en cas de compromission. Les principales zones couvrent les usages pédagogiques, administratifs, techniques, serveurs et les accès invités.

Les communications entre zones sont contrôlées par pare-feu selon le principe du moindre privilège : par défaut, tout est interdit sauf autorisation explicite validée par le RSSI.

## 5.2-Routage sécurisé

Les flux réseau doivent être protégés contre toute interception, altération ou redirection non autorisée. Les mécanismes de routage doivent garantir que seuls des équipements autorisés participent aux échanges et que les informations de routage ne puissent pas être manipulées frauduleusement.

Les règles de sécurisation du routage et des flux sont définies et contrôlées par les équipes techniques sous la responsabilité du RSSI.

## 5.3-Contrôle des accès réseau

L'accès au réseau doit être conditionné à l'identification des utilisateurs et à la conformité des équipements. Seuls les équipements et utilisateurs autorisés peuvent accéder aux ressources internes du système d'information.

Les dispositifs de contrôle des accès réseau doivent permettre de limiter ou de restreindre l'accès en cas de non-conformité ou de comportement à risque, conformément aux règles définies par la politique de sécurité.

## 5.4-Surveillance des communications

L'accès au réseau doit être conditionné à l'identification des utilisateurs et à la conformité des équipements. Seuls les équipements et utilisateurs autorisés peuvent accéder aux ressources internes du système d'information.

Les dispositifs de contrôle des accès réseau doivent permettre de limiter ou de restreindre l'accès en cas de non-conformité ou de comportement à risque, conformément aux règles définies par la politique de sécurité.

# 6. Sécurité applicative

## 6.1-Sécurité intégrée au cycle de vie des applications

Toute application déployée ou utilisée dans le périmètre de la DSNEP doit intégrer des exigences de sécurité dès les phases de conception. Une analyse des risques est réalisée préalablement à tout développement ou acquisition, et fait l'objet d'une validation par le RSSI.

Les règles de sécurité applicative s'appliquent aux phases de développement, de test, de mise en production et d'exploitation. Les responsabilités en matière de sécurité sont clairement définies entre les équipes métiers, les équipes techniques et les prestataires.

## 6.2-Gestion des mises à jour et correctifs

La DSNEP met en place une organisation permettant l'identification, l'évaluation et le traitement des vulnérabilités affectant les applications. Les correctifs de sécurité sont appliqués selon des priorités définies en fonction du niveau de risque et de l'impact potentiel sur les activités.

Les processus de gestion des mises à jour sont formalisés, documentés et intégrés au fonctionnement courant des services numériques.

## 6.3- Contrôle des accès applicatifs

L'accès aux applications est encadré par des règles garantissant que seuls les utilisateurs autorisés peuvent accéder aux données et fonctionnalités correspondant à leurs missions. Les principes du moindre privilège et de séparation des rôles sont appliqués.

Les accès aux applications sensibles font l'objet d'une traçabilité permettant de détecter les usages anormaux et de répondre aux exigences réglementaires. Les modalités d'attribution, de révision et de suppression des droits sont définies et contrôlées par les responsables habilités.

# 7. Sauvegarde et résilience

## 7.1 Objectif de la politique de sauvegarde

La politique de sauvegarde de la DSNEP vise à garantir la pérennité, la disponibilité et la récupérabilité des informations nécessaires au fonctionnement des services numériques éducatifs du primaire.

Elle constitue un élément fondamental de la résilience du système d'information face aux incidents, erreurs humaines, sinistres ou actes malveillants.

Les objectifs poursuivis sont les suivants :

- Assurer la continuité du service public éducatif,
- Prévenir la perte définitive de données sensibles, en particulier celles relatives aux élèves et aux personnels,
- Permettre une reprise d'activité dans des délais compatibles avec les missions pédagogiques et administratives,

- Répondre aux obligations réglementaires et aux exigences de traçabilité.

## 7.2 Périmètre des sauvegardes

La politique de sauvegarde couvre l'ensemble des données identifiées comme critiques ou sensibles dans le cadre de la classification de l'information, notamment :

- Les données scolaires et pédagogiques,
- Les données administratives et organisationnelles,
- Les informations nécessaires au fonctionnement des services numériques éducatifs.

Les modalités de sauvegarde tiennent compte du niveau de criticité des données, tel que défini dans la classification de l'information, et s'inscrivent dans une logique de proportionnalité.

## 7.3 Principes organisationnels

La DSNEP applique des principes organisationnels clairs afin de garantir l'efficacité et la fiabilité des sauvegardes :

- Formalisation des responsabilités liées à la sauvegarde et à la restauration,
- Séparation des rôles entre les acteurs responsables de l'exploitation et ceux chargés du contrôle,
- Documentation systématique des procédures de sauvegarde et de restauration,
- Mise à jour régulière de la politique en fonction de l'évolution des besoins et des risques.

## 7.4 Test et amélioration continue

Des tests réguliers de restauration sont organisés afin de vérifier l'efficacité des sauvegardes et la capacité de l'organisation à rétablir les services dans des conditions maîtrisées.

Les résultats de ces tests font l'objet d'un suivi et, le cas échéant, de plans d'amélioration.

La politique de sauvegarde s'inscrit dans une démarche d'amélioration continue, intégrée à la gouvernance globale de la sécurité des systèmes d'information.

## 8. Journalisation et supervision

### 8.1 Objectifs de la journalisation

La journalisation vise à assurer la traçabilité des événements significatifs affectant la sécurité des systèmes d'information de la DSNEP.

Elle constitue un outil essentiel de :

- Détection des incidents de sécurité,
- Analyse a posteriori des événements,
- Production d'éléments de preuve en cas d'audit ou d'investigation,
- Respect des obligations légales et réglementaires.

### 8.2 Principes de gouvernance

La DSNEP met en œuvre une organisation de la journalisation reposant sur les principes suivants :

- Définition des événements devant faire l'objet d'une traçabilité,
- Centralisation organisationnelle des informations de journalisation,
- Protection de l'intégrité et de la confidentialité des journaux,
- Accès restreint aux données de journalisation, limité aux personnes habilitées.

Les durées de conservation des journaux sont définies en conformité avec les obligations réglementaires et les recommandations en vigueur.

### 8.3 Exploitation des journaux

Les journaux sont exploités dans un cadre strictement professionnel et encadré, dans le respect des droits des agents et des usagers.

Ils peuvent être utilisés pour :

- Identifier des comportements anormaux,
- Appuyer la gestion des incidents de sécurité,
- Contribuer à l'amélioration des dispositifs organisationnels de sécurité.

Toute utilisation des journaux à des fins autres que celles prévues par la PSSI est proscrite.

## 9. Gestion des incidents de sécurité

### 9.1 Objectifs

La gestion des incidents de sécurité a pour objectif de garantir une réaction rapide, coordonnée et proportionnée face à tout événement susceptible d'affecter la sécurité du système d'information ou la continuité des services éducatifs.

Elle vise à :

- Limiter les impacts sur les activités pédagogiques et administratives,
- Préserver les données et les actifs informationnels,
- Assurer une communication maîtrisée,
- Tirer des enseignements pour prévenir la récurrence des incidents.

## 9.2 Organisation et responsabilités

La DSNEP définit une organisation claire de la gestion des incidents, reposant sur :

- L'identification des rôles et responsabilités des acteurs impliqués,
- La désignation d'un point de coordination,
- L'existence de circuits de décision et d'escalade formalisés.

Tout agent ou utilisateur est tenu de signaler sans délai tout incident ou suspicion d'incident de sécurité selon les modalités définies par la DSNE.

## 9.3 Processus de gestion des incidents

Le processus de gestion des incidents comprend les étapes suivantes :

1. Détection et signalement de l'incident,
2. Qualification et évaluation de l'impact,
3. Mise en œuvre de mesures de maîtrise,
4. Communication interne et, le cas échéant, externe,
5. Retour d'expérience et actions correctives.

Ce processus est documenté, connu des acteurs concernés et régulièrement mis à jour.

## 9.4 Communication et obligation réglementaire

La communication relative aux incidents de sécurité est strictement encadrée afin de :

- Éviter toute diffusion d'information non maîtrisée
- Préserver la confiance des usagers
- Respecter les obligations légales, notamment en matière de protection des données à caractère personnel

L'obligation réglementaire impose de prévenir les autorités en cas de violation de données et les personnes concernées lorsque cela a un impact sur leurs droits

## 10. Plan de Continuité & de Reprise d'Activité

### 10.1 PCA

Le Plan de Continuité d'Activité a pour objectif de maintenir, en mode dégradé si nécessaire, les activités et services numériques essentiels en cas de crise ou d'incident majeur. Il repose sur l'identification préalable des activités critiques de la DSNEP et sur la priorisation des services éducatifs indispensables à la continuité pédagogique et administrative.

Les activités et services identifiés comme critiques font l'objet de mesures organisationnelles spécifiques visant à garantir leur maintien, telles que la définition de procédures de fonctionnement dégradé, l'organisation des ressources humaines nécessaires à la continuité d'activité et la formalisation des circuits de décision en situation de crise.

Le PCA est documenté, validé par la direction et régulièrement révisé afin de garantir son adéquation avec l'évolution des missions, des services numériques et de l'organisation de la DSNEP.

### 10.2 PRA

Le Plan de Reprise d'Activité définit les modalités de restauration des systèmes d'information et des services numériques après un sinistre ou un incident majeur ayant entraîné une interruption significative. Il formalise les procédures de reprise, les responsabilités associées et les priorités de remise en service des applications et des données.

Le PRA s'appuie notamment sur l'exploitation des mécanismes de sauvegarde et de restauration afin d'assurer la récupération des données et des services dans des délais compatibles avec les exigences du service public éducatif. Des objectifs de reprise sont définis pour chaque service critique, incluant les délais maximaux de reprise (RTO) et les pertes de données admissibles (RPO).

Le PRA fait l'objet de tests périodiques et de mises à jour régulières afin de garantir son efficacité opérationnelle et son adéquation aux risques identifiés.

## 11. Sensibilisation

La sécurité des systèmes d'information repose en grande partie sur les comportements et les pratiques des utilisateurs. La Ville de Rennes met en œuvre une démarche de sensibilisation continue à la sécurité de l'information afin de développer une culture partagée de cybersécurité au sein des services numériques éducatifs.

Les actions de sensibilisation s'adressent à l'ensemble des utilisateurs des systèmes d'information relevant du périmètre de la DSNEP, incluant les agents municipaux, les personnels éducatifs, ainsi que, de manière adaptée, les autres usagers des services numériques éducatifs. Elles visent à renforcer la compréhension des risques numériques, à promouvoir les bonnes pratiques de sécurité et à réduire les risques liés aux erreurs humaines.

La sensibilisation porte notamment sur les principes fondamentaux de la sécurité de l'information, la protection des données à caractère personnel, la gestion des mots de passe et des accès, la détection des tentatives de phishing, ainsi que les comportements à adopter en cas d'incident ou de suspicion d'incident de sécurité.

Les actions de sensibilisation sont mises en œuvre de manière régulière, sous des formes adaptées aux publics concernés (communications internes, supports pédagogiques, campagnes d'information). Leur efficacité est suivie et prise en compte dans l'amélioration continue des pratiques de sécurité au sein de la DSNEP.

Direction des Systèmes Numériques Éducatifs du Primaire (DSNEP)

# Politique de Sécurité des Systèmes d'Information

Volet Technique

| Version | Rédacteur              | Autorité<br>d'approbation                | Date d'approbation |
|---------|------------------------|------------------------------------------|--------------------|
| V1.00   | Groupe de Travail PSSI | Comité Stratégique<br>de Sécurité des SI | 15/01/2026         |

Louis AUBERT – Ludivine PERRIER-BABIN – Ulrich  
FOKAM-GOUAYOU – Solange Dominique EYAGA NDEME  
– Jean-Marc AWAD  
15/01/2026

# Introduction

La PSSI technique décline opérationnellement les principes de la PSSI organisationnelle, en conformité avec le RGPD, les recommandations de l'ANSSI applicables aux collectivités territoriales et les bonnes pratiques issues des normes ISO/IEC 27001.

## 1.Périmètre

### 1.1 Champs d'application

La Politique de Sécurité des Systèmes d'Information technique s'applique à l'ensemble des infrastructures, systèmes, applications et services numériques exploités par la Direction des Systèmes Numériques Éducatifs du Primaire (DSNEP) de la Ville de Rennes. Elle couvre tous les environnements techniques participant aux missions éducatives numériques, qu'ils soient hébergés en interne, dans des centres de données externalisés ou fournis par des prestataires tiers.

Le périmètre inclut notamment les réseaux des établissements scolaires, les serveurs physiques et virtualisés, les environnements cloud, les postes de travail des agents et des personnels éducatifs, les équipements pédagogiques, ainsi que les applications éducatives, administratives et métiers. Les outils de sécurité, de supervision et de gestion des identités sont pleinement intégrés à ce périmètre.

La présente PSSI technique s'impose à l'ensemble des acteurs disposant d'un accès, direct ou indirect, au système d'information, y compris les prestataires et sous-traitants, pendant toute la durée de leur intervention.

### 1.2 Acteurs et rôles techniques

Les acteurs intervenant dans le périmètre technique de la sécurité des systèmes d'information sont clairement identifiés afin de garantir une gouvernance efficace et une responsabilité maîtrisée.

#### Acteurs internes

- Responsable de la Sécurité des Systèmes d'Information (RSSI)  
Définit les exigences de sécurité technique, valide les architectures sécurisées, pilote la gestion des risques et coordonne la réponse aux incidents majeurs.
- Administrateurs systèmes  
Assurent l'installation, la configuration, la sécurisation et la maintenance des serveurs, systèmes d'exploitation et plateformes de virtualisation.

- Administrateurs réseaux  
Conçoivent et exploitent les architectures réseau, assurent la segmentation, le filtrage des flux, le routage sécurisé et la disponibilité des communications.
- Administrateurs applicatifs  
Garantissent la sécurité des applications, la gestion des accès applicatifs et la protection des données traitées.
- Équipes d'exploitation et de support  
Supervisent les systèmes, traitent les alertes, assurent le support utilisateur et appliquent les procédures de sécurité opérationnelles.

#### Acteurs externes

- Prestataires et sous-traitants techniques  
Interviennent dans un cadre contractuel intégrant des clauses de sécurité, de confidentialité et de traçabilité des accès.

### 1.3 Identification et typologie des actifs

Conformément à la PSSI organisationnelle, la sécurité technique repose sur une identification exhaustive et documentée des actifs contribuant au système d'information éducatif.

Les actifs techniques sont recensés dans un référentiel centralisé et classifiés selon leur rôle, leur criticité et les données traitées.

- Actifs supports  
Infrastructures réseau, équipements de sécurité périmétrique, serveurs physiques et virtualisés, solutions de stockage et de sauvegarde, postes de travail, équipements mobiles et matériels pédagogiques connectés.
- Actifs logiciels  
Systèmes d'exploitation, applications éducatives et administratives, ENT, outils de gestion des identités, plateformes de supervision, de journalisation et de corrélation des événements.
- Actifs humains techniques  
Administrateurs, exploitants, utilisateurs disposant d'accès techniques, prestataires et intervenants externes.

Chaque actif est associé à un propriétaire technique responsable de son maintien en condition de sécurité, de sa conformité aux exigences de la PSSI et de la gestion de son cycle de vie.

### 1.4 Cartographie et criticité des actifs

Une cartographie technique des actifs du système d'information de la DSNEP est établie et maintenue sous la responsabilité du RSSI. Elle fournit une vision globale des

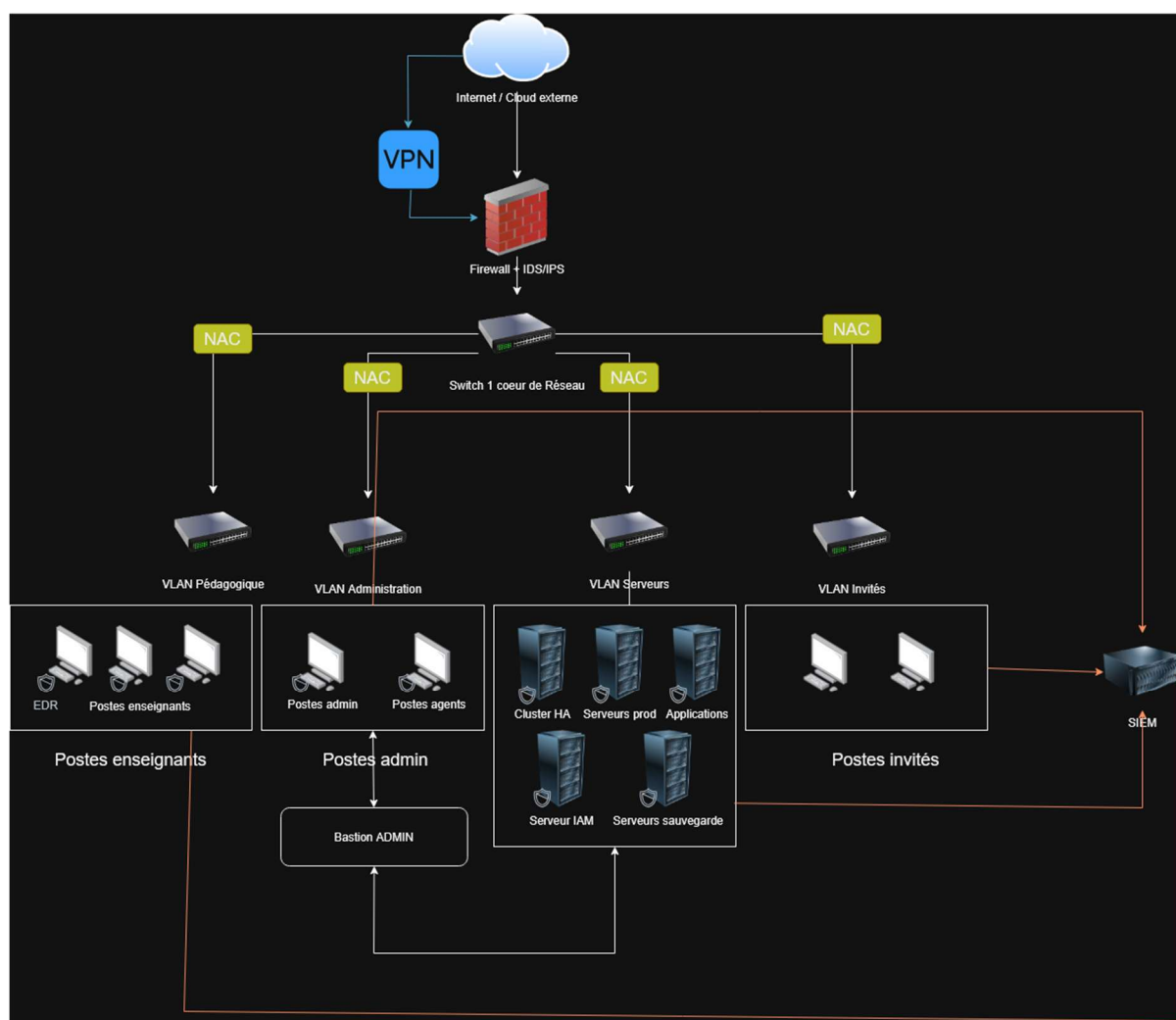
infrastructures, des systèmes, des applications et des flux de communication, ainsi que des dépendances entre les services numériques. Cette cartographie est formalisée à partir des inventaires techniques existants (systèmes, réseaux, virtualisation, cloud, outils de supervision) et est documentée sous forme de schémas d'architecture logique.

La cartographie est mise à jour de manière régulière et à chaque évolution significative de l'architecture ou des services numériques, notamment lors de l'introduction de nouveaux équipements, de la modification des flux réseau ou du recours à un nouveau prestataire. Toute évolution est validée par le RSSI afin de garantir la cohérence globale de la sécurité technique.

Pour chaque actif identifié, une évaluation de criticité est réalisée selon les critères de confidentialité, d'intégrité et de disponibilité. La confidentialité est appréciée en fonction de la sensibilité des données traitées, l'intégrité au regard des impacts d'une altération des informations, et la disponibilité en fonction des conséquences d'une interruption de service sur les activités éducatives et administratives.

Cette évaluation permet de prioriser les mesures de sécurité, d'orienter les choix d'architecture technique et de définir les exigences en matière de sauvegarde, de supervision et de continuité d'activité pour chaque actif.

## 1.5 Schéma d'architecture du système d'information



## 2. Classification de l'information

### 2.1 Principes et objectifs

La classification de l'information constitue un fondement essentiel de la sécurité technique du système d'information de la DSNEP. Elle vise à adapter les mesures de protection aux risques associés aux données traitées, en tenant compte de leur sensibilité et des impacts potentiels en cas de compromission.

Cette classification s'applique à l'ensemble des informations, quel que soit leur support ou leur mode de traitement, qu'il s'agisse de stockage, de transit, de sauvegarde ou d'archivage. Elle permet d'assurer une protection proportionnée et cohérente, en conformité avec les exigences réglementaires, notamment celles relatives à la protection des données à caractère personnel.

## 2.2 Typologie des données traitées

Les systèmes d'information de la DSNEP traitent des données de nature variée, incluant des données à caractère personnel relatives aux élèves mineurs et à leurs représentants légaux, des données pédagogiques et scolaires, des données administratives et de ressources humaines, des données financières, ainsi que des données techniques telles que les journaux, les configurations et les métriques de supervision. Des données contractuelles et réglementaires peuvent également être traitées dans le cadre des relations avec les partenaires et prestataires.

## 2.3 Niveaux de classification

Les informations sont classifiées selon quatre niveaux de sensibilité, permettant d'adapter les exigences techniques de protection :

- Public : informations pouvant être diffusées sans restriction particulière
- Interne : informations destinées à un usage professionnel interne, dont la divulgation non autorisée aurait un impact limité
- Sensible : informations nécessitant un accès restreint, dont la compromission pourrait avoir des impacts significatifs
- Critique : informations dont la compromission aurait des conséquences majeures, notamment juridiques, financières ou réputationnelles

## 2.4 Exigences techniques associées

Chaque niveau de classification est associé à des exigences techniques minimales en matière de contrôle d'accès, de chiffrement, de traçabilité, de sauvegarde et de supervision. Les données sensibles et critiques font l'objet de mesures renforcées, incluant notamment le chiffrement des données au repos et en transit, une journalisation détaillée des accès et des actions, ainsi qu'une supervision accrue des systèmes les traitant.

Les exigences techniques sont définies de manière proportionnée afin de garantir un niveau de protection adapté sans entraver inutilement les usages pédagogiques et administratifs.

## 2.5 Priorisation et gestion des risques

La classification de l'information constitue un levier central de la gestion des risques techniques. Elle permet d'identifier les actifs et les données nécessitant une attention prioritaire, d'orienter les investissements en matière de sécurité et de définir les niveaux de service attendus en termes de disponibilité et de reprise d'activité.

Toute évolution significative des types de données traitées, des usages ou des systèmes concernés entraîne une réévaluation de la classification et, le cas échéant, l'adaptation des mesures de sécurité associées.

### 3. Gestion des accès et des identités

#### 3.1 Principes techniques

La gestion des accès aux systèmes d'information de la DSNEP repose sur le principe du moindre privilège. Chaque compte technique ou utilisateur se voit attribuer uniquement les droits nécessaires à l'exécution de ses missions, pour une durée strictement limitée.

Les rôles sont clairement séparés entre administration, exploitation et supervision afin de réduire les risques d'erreur, d'abus ou de compromission d'un compte à privilèges.

Les identités et les accès sont gérés de manière centralisée au sein d'un système de gestion des identités et des accès (IAM), permettant une cohérence des droits sur l'ensemble du périmètre technique.

Tous les accès, qu'ils soient logiques ou administratifs, font l'objet d'une traçabilité systématique afin de permettre les contrôles, audits et investigations en cas d'incident de sécurité.

#### 3.2 Privilèges

Les comptes utilisateurs standards (agents, enseignants, personnels éducatifs) disposent de droits limités aux usages quotidiens nécessaires à leurs activités.

Les comptes à privilèges, destinés aux administrateurs systèmes, réseaux et applicatifs, sont strictement réservés aux opérations d'administration et ne doivent pas être utilisés pour des usages courants.

Les comptes de service sont dédiés à des usages techniques précis (applications, automatisations, interconnexions) et configurés avec des droits minimaux. Leur usage est documenté et régulièrement revu.

Les accès accordés aux prestataires techniques sont temporaires, limités dans le temps et périmètres selon la nature de l'intervention. Ils font l'objet d'une supervision renforcée.

L'utilisation de comptes partagés est formellement interdite afin de garantir l'identification individuelle des actions et la responsabilité de chaque intervenant.

#### 3.3 Authentification

Les mécanismes d'authentification mis en œuvre sont adaptés au niveau de sensibilité des ressources accessibles. Une authentification multifacteur (MFA) est obligatoire

pour les comptes sensibles, notamment les comptes administrateurs et les accès aux systèmes critiques.

Des politiques de mots de passe robustes sont appliquées, incluant des exigences de complexité, de renouvellement et de protection contre les tentatives d'authentification abusives. Les accès à privilèges sont accordés pour une durée limitée et réévalués régulièrement.

Pour les environnements critiques, les accès administratifs sont réalisés via un bastion d'administration permettant de centraliser, contrôler et tracer l'ensemble des connexions et des actions effectuées.

### 3.4 Gestion des accès physiques

L'accès aux infrastructures critiques de la DSNEP, telles que les salles serveurs, les datacenters municipaux et les bureaux administratifs sensibles, est strictement encadré afin de protéger les actifs et les données sensibles. Seules les personnes habilitées, identifiées et autorisées par la DSNEP peuvent pénétrer dans ces zones.

Les mesures mises en œuvre comprennent la mise en place de contrôles d'accès physiques, incluant l'utilisation de badges sécurisés, de lecteurs biométriques et de serrures électroniques. Les entrées et sorties sont systématiquement journalisées avec horodatage, permettant de tracer toutes les interventions.

Le nombre de personnes présentes simultanément dans les zones sensibles est limité, et les droits d'accès sont régulièrement revus et révoqués immédiatement en cas de changement de rôle ou de départ d'un collaborateur.

Pour les interventions de prestataires ou de tiers, un accompagnement par un agent habilité est obligatoire et toutes les actions effectuées sont consignées.

## 4. Sécurité des postes et des serveurs

### 4.1 Postes de travail

Tous les postes de travail des agents, enseignants et personnels éducatifs sont administrés via une gestion centralisée des configurations, assurant le déploiement uniforme des paramètres de sécurité et des correctifs sur l'ensemble des machines. Les disques sont systématiquement chiffrés pour protéger les données en cas de perte ou de vol. Chaque poste est équipé d'un agent antivirus et d'une EDR, permettant la détection en temps réel des malwares, ransomwares ou comportements anormaux, avec remontée centralisée des alertes vers la plateforme de supervision. Les mises à jour système et logicielles sont appliquées automatiquement selon une planification définie et contrôlée. L'utilisation de droits administrateur locaux est strictement

restreinte afin de limiter l'installation de logiciels non autorisés. Les périphériques externes, notamment les clés USB, sont soumis à un contrôle d'accès et d'usage pour prévenir toute introduction de menaces sur le réseau et les systèmes. Tout équipement dont le système d'exploitation n'est plus maintenu par l'éditeur est considéré comme une vulnérabilité majeure. Ces systèmes doivent être retirés du parc ou, par exception motivée, placés dans une zone réseau isolée (quarantaine) sans aucun accès Internet ni communication avec le reste du SI.

## 4.2 Serveurs

Les serveurs sont organisés en environnements cloisonnés correspondant à la production, aux tests et à l'administration. Chaque serveur est durci selon les bonnes pratiques de sécurité, avec désactivation des services non essentiels et renforcement des configurations critiques. Les correctifs de sécurité sont appliqués régulièrement, soit automatiquement, soit via des procédures de maintenance planifiées et auditées. L'accès administrateur est limité aux personnes habilitées et chaque action est tracée afin de garantir la responsabilité et la traçabilité complète. La disponibilité et la performance des services sont surveillées en continu à l'aide d'outils de supervision centralisés, permettant de détecter rapidement tout incident technique ou anomalie dans le fonctionnement des systèmes.

# 5. Sécurité des réseaux

## 5.1 Segmentation logique des flux

Le réseau est segmenté en zones fonctionnelles étanches au moyen de VLAN et de règles de filtrage implémentées sur des pare-feu de nouvelle génération.

| Zone           | Utilisateurs          | Sensibilité |
|----------------|-----------------------|-------------|
| Pédagogique    | Élèves, enseignants   | Moyen       |
| Administrative | Agents, direction     | Élevé       |
| Invités        | Visiteurs externes    | Faible      |
| Technique      | Infrastructure        | Critique    |
| Serveurs       | Applications, données | Critique    |

## 5.2 Routage sécurisé

Les chemins empruntés par les informations sont protégés contre toute manipulation frauduleuse :

- Authentification des équipements réseau : seuls les équipements légitimes participent aux échanges de routage
- Vérification de l'intégrité : protection contre les modifications frauduleuses des informations de routage
- Filtrage des annonces : seules les routes légitimes sont acceptées et propagées
- Renouvellement périodique : changement régulier des éléments d'authentification
- Interdiction des protocoles non sécurisés : Les protocoles ne supportant pas le chiffrement ou présentant des vulnérabilités connues sont proscrits.  
L'administration et les transferts doivent obligatoirement transiter via des protocoles sécurisés

## 5.3 Contrôle des accès réseau (NAC)

Avant connexion, chaque équipement doit satisfaire à des vérifications garantissant son identité et sa conformité :

- Double authentification : vérification de l'utilisateur (identifiants personnels + second facteur pour accès sensibles) et validation de l'équipement
- Évaluation de conformité : antivirus actif et à jour, correctifs installés, pare-feu activé, chiffrement du disque
- Sécurisation du Wi-Fi : Les accès sans fil pédagogiques utilisent le standard WPA2/WPA3-Entreprise. L'authentification est strictement individuelle via le protocole 802.1X. L'usage de clés partagées (WPA-PSK) est interdit pour les usages permanents afin d'éviter la compromission du réseau par simple diffusion de la clé.

Accès réseau et authentification :

| Type d'accès             | Méthode d'authentification | Niveau de sécurité |
|--------------------------|----------------------------|--------------------|
| Accès standard (local)   | Mot de passe               | Modéré             |
| Accès standard (distant) | Mot de passe + MFA         | Élevé              |
| Compte à privilèges      | MFA renforcé               | Critique           |

Quarantaine : équipements non conformes isolés avec accès limité aux serveurs de mise à jour, déconnexion après 48h sans remédiation.

## 5.4 Surveillance des communications

Une plateforme centralisée surveille en continu les 85 établissements pour détecter rapidement les menaces. Les événements sont corrélés et traités selon une criticité

définie, permettant une réponse graduée. Les journaux de sécurité sont conservés pour des durées adaptées à la criticité des systèmes, avec des mécanismes garantissant leur intégrité et leur disponibilité :

- Triple détection : signatures d'attaques connues (base mise à jour quotidiennement), analyse comportementale (anomalies), renseignement sur les menaces (domaines et adresses malveillants)
- Réactivité graduée : incidents critiques (notification immédiate, cellule de crise), majeurs (investigation sous 2h), mineurs (traitement différé)
- Conservation des journaux : 3 à 24 mois selon criticité, avec protection de l'intégrité (chiffrement, sauvegardes déconnectées)

## 6. Sécurité applicative

### 6.1 Sécurité intégrée au cycle de vie des applications

Les applications constituent le point d'interaction principal entre les utilisateurs et les données sensibles. Leur sécurisation repose sur quatre piliers organisationnels complémentaires garantissant la protection tout au long de leur existence.

|               |                                                             |
|---------------|-------------------------------------------------------------|
| Conception    | Analyse des risques et validation RSSI obligatoire          |
| Développement | Bonnes pratiques de codage sécurisé                         |
| Tests         | Tests de sécurité automatisés avant déploiement             |
| Exploitation  | Surveillance continue et maintien en conditions de sécurité |

Les applications en production font l'objet d'une surveillance continue et d'un maintien en conditions de sécurité assuré par les équipes techniques.

### 6.2 Gestion des mises à jour et correctifs

Les vulnérabilités découvertes sont corrigées selon des délais adaptés au niveau de risque (ces délais peuvent être ajustés en fonction de la criticité des systèmes impactés des contraintes opérationnelles, après validation du RSSI) :

- Vulnérabilités critiques : correction sous 15 jours maximum
- Vulnérabilités importantes : correction sous 45 jours lors des maintenances mensuelles
- Vulnérabilités modérées : correction sous 90 jours lors des maintenances trimestrielles

Une veille quotidienne sur les bulletins de sécurité permet d'identifier rapidement les correctifs applicables. Chaque mise à jour est testée avant déploiement pour garantir la compatibilité avec l'environnement existant.

### 6.3 Contrôle des accès applicatifs

L'accès aux applications est strictement contrôlé pour protéger les données sensibles :

- Authentification renforcée : identifiants personnels uniques, mots de passe robustes (12 caractères minimum), double authentification pour les applications sensibles
- Principe du moindre privilège : chaque utilisateur ne dispose que des droits strictement nécessaires à ses fonctions
- Révision systématique : contrôle annuel des habilitations, suppression immédiate des droits en cas de changement de fonction ou de départ
- Traçabilité complète : journalisation de tous les accès aux applications sensibles (conservation 12 mois)

## 7. Sauvegarde et résilience

### 7.1 Objectifs techniques

La politique de sauvegarde technique de la DSNEP a pour objectif de garantir la protection, la disponibilité et la restaurabilité des données et services numériques éducatifs, en cas d'incident de sécurité, de défaillance matérielle, d'erreur humaine ou d'attaque malveillante (notamment rançongiciel).

Cette politique vise à :

- Assurer la continuité des services pédagogiques et administratifs,
- Garantir la récupération des données scolaires et personnelles des élèves mineurs,
- Limiter les impacts opérationnels en cas de sinistre,
- Respecter les exigences réglementaires liées au RGPD et aux recommandations de l'ANSSI.

### 7.2 Stratégie et architecture de sauvegarde

La DSNEP applique une stratégie de sauvegarde 3-2-1, structurée comme suit :

- 3 copies des données (données de production + deux copies de sauvegarde),

- 2 supports différents (stockage principal + stockage secondaire),
- 1 copie hors ligne ou hors site, protégée contre les attaques de type chiffrement massif.

Les sauvegardes couvrent :

- Les bases de données pédagogiques et administratives,
- Les applications éducatives critiques (ENT, services de gestion scolaire),
- Les configurations systèmes et applicatives,
- Les machines virtuelles hébergeant les services essentiels.

L'architecture de sauvegarde repose sur une plateforme centralisée de sauvegarde, intégrée à l'infrastructure de virtualisation et aux environnements de stockage.

### 7.3 Type de sauvegardes mise en œuvre

Les mécanismes de sauvegarde s'appuient sur une combinaison de méthodes complémentaires :

- Sauvegarde complète  
Réalisée périodiquement afin de disposer d'un point de restauration intégral et fiable.
- Sauvegarde incrémentielle  
Capturant uniquement les modifications depuis la dernière sauvegarde, afin d'optimiser les volumes et les temps de sauvegarde.
- Sauvegarde différentielle  
Utilisée pour certains services critiques afin de réduire le temps de restauration tout en limitant l'espace de stockage.

Les fréquences de sauvegarde sont définies en fonction de la criticité des données et des objectifs RPO définis dans le PRA.

### 7.4 Sécurisation des sauvegardes

Afin de garantir la confidentialité et l'intégrité des données sauvegardées, les mesures techniques suivantes sont appliquées :

- Chiffrement systématique des sauvegardes, aussi bien au repos que lors des transferts,
- Contrôle strict des accès aux infrastructures de sauvegarde, réservé à des comptes techniques dédiés,
- Isolation des environnements de sauvegarde afin de limiter les risques de compromission latérale,

- Immutabilité des sauvegardes critiques, empêchant leur modification ou suppression pendant une durée définie.
- Gestion des clés : Les clés de chiffrement (disques et sauvegardes) sont conservées de manière sécurisée et centralisée dans un coffre-fort numérique (KMS). Une copie de secours des clés "maîtresses" est stockée de façon déconnectée (coffre-fort physique) pour garantir l'accès aux données même en cas de destruction totale de l'infrastructure d'administration.

Les accès aux supports de sauvegarde font l'objet d'une journalisation complète et d'une supervision renforcée.

## 7.5 Test de restauration et amélioration continue

Des tests réguliers de restauration sont planifiés et exécutés afin de :

- Valider l'intégrité des sauvegardes,
- Mesurer les délais réels de reprise,
- Vérifier la conformité avec les objectifs RTO et RPO définis,
- S'assurer de la capacité opérationnelle des équipes techniques.

Les résultats des tests sont documentés et analysés. Toute anomalie constatée donne lieu à des actions correctives, permettant l'amélioration continue de la résilience du système d'information de la DSNEP.

# 8. Journalisation et supervision

## 8.1 Objectifs techniques

La journalisation constitue un pilier fondamental de la sécurité technique du système d'information de la DSNEP. Elle permet d'assurer une traçabilité exhaustive des événements, indispensable à la détection, l'analyse et la gestion des incidents de sécurité.

Les objectifs sont :

- Détecter les comportements anormaux ou malveillants,
- Faciliter les investigations techniques,
- Produire des preuves exploitables lors d'audits ou d'incidents,
- Répondre aux obligations réglementaires et de conformité.

## 8.2 Architecture de journalisation

La DSNEP met en œuvre une architecture centralisée de collecte des journaux, couvrant l'ensemble des composants du système d'information :

- Systèmes d'exploitation (postes et serveurs),
- Équipements réseau et de sécurité,
- Applications éducatives et administratives,
- Plateformes de virtualisation et de stockage,
- Services d'authentification et de gestion des identités.

Les journaux sont transmis vers une plateforme SIEM (Security Information and Event Management) assurant la centralisation, la normalisation et la corrélation des événements.

Durée de conservation des logs :

| Type de Journal              | Durée de conservation | Justification |
|------------------------------|-----------------------|---------------|
| Authentification             | 12 mois               | CNIL          |
| Événements de sécurité       | 12 mois               | Investigation |
| Accès applications sensibles | 12 mois               | RGPD          |
| Pare-feu/IDS                 | 6 mois                | Performance   |
| Logs technique systèmes      | 3 mois                | Exploitation  |

## 8.3 Corrélation et détection d'incidents

La plateforme SIEM permet :

- La corrélation automatique des événements issus de sources multiples,
- La détection de signatures d'attaques connues avec un EDR,
- L'identification de comportements anormaux par analyse contextuelle,
- L'analyse des flux réseaux et détection d'intrusions avec les sondes IDS/IPS
- L'intégration de renseignements sur les menaces (indicateurs de compromission).

Les alertes sont qualifiées selon leur criticité et transmises aux équipes techniques pour traitement, conformément aux processus de gestion des incidents définis dans la PSSI.

#### 8.4 Supervision des infrastructures et des services

En complément de la journalisation de sécurité, la DSNEP déploie des outils de supervision technique permettant le suivi en temps réel :

- De la disponibilité des services numériques éducatifs,
- Des performances des systèmes et des réseaux,
- De l'état de santé des équipements critiques,
- Des capacités de stockage et de sauvegarde.

Cette supervision permet d'anticiper les incidents, de détecter les dégradations de service et de garantir un niveau de disponibilité compatible avec les exigences du service public éducatif.

#### 8.5 Indicateurs et tableaux de bord

Les données issues de la journalisation et de la supervision alimentent des tableaux de bord techniques, permettant de suivre notamment :

- Le taux de disponibilité des services critiques,
- Le nombre et la typologie des incidents de sécurité,
- Le délai moyen de détection (MTTD),
- Le délai moyen de résolution (MTTR),
- Le niveau de conformité des postes et des serveurs.

Ces indicateurs constituent un outil d'aide à la décision pour le RSSI et les équipes techniques, et contribuent à l'amélioration continue de la posture de sécurité de la DSNEP.

## 9. Gestion des incidents de sécurité

### 9.1 Organisation technique

La gestion des incidents repose sur l'exploitation des données issues de la plateforme de supervision (SIEM/EDR) par un Centre d'Opérations de Sécurité (SOC) externe. Ce dispositif garantit une capacité de réaction 24h/24 et 7j/7, indépendante des heures d'ouverture de la collectivité.

Missions du SOC :

- Qualification : Analyse des alertes remontées par le SIEM pour éliminer les faux positifs.
- Alerte et Escalade : Notification immédiate du RSSI ou des astreintes techniques selon une matrice de criticité définie avec le prestataire SOC et validés par le RSSI.
- Mesures Conservatoires : En cas de menace critique avérée, le SOC est habilité à appliquer des mesures de confinement immédiates pour stopper la propagation.

Les incidents qualifiés sont intégrés dans un outil de gestion des incidents assurant le suivi des actions de remédiation, la traçabilité des décisions et la capitalisation.

## 9.2 Indicateurs

Les dispositifs techniques de gestion des incidents intègrent des mécanismes de mesure permettant de suivre l'efficacité de la détection et de la résolution des incidents de sécurité.

Les principaux indicateurs techniques suivis sont :

- Nombre d'incidents par catégorie, issu de la corrélation des alertes de sécurité (malwares, compromissions de comptes, incidents réseau, indisponibilités de services)
- Temps de résolution technique, mesuré entre la détection automatisée par les outils de supervision et le retour à un état nominal des systèmes
- Taux de récurrence des incidents, permettant d'identifier les vulnérabilités techniques persistantes ou les configurations inadéquates
- Impact sur la disponibilité, évalué à partir des métriques de supervision (temps d'indisponibilité, dégradation de performance des services critiques)

Ces indicateurs sont produits automatiquement par les outils de supervision, de sécurité et de gestion des incidents. Ils alimentent les tableaux de bord techniques et contribuent à l'amélioration continue des dispositifs de sécurité.

## 10. PCA / PRA

### 10.1 Continuité (PCA)

La continuité de service repose techniquement sur une architecture dite de « Haute Disponibilité » (High Availability - HA) conçue pour éliminer, autant que possible, les points de défaillance uniques (SPOF) au sein de l'infrastructure de la DSNEP.

Au niveau des systèmes centraux, la continuité est assurée par la mise en œuvre de clusters de virtualisation. Ces grappes de serveurs sont configurées pour permettre le basculement automatique et immédiat des machines virtuelles critiques (serveurs d'authentification, bases de données élèves, ENT) d'un hyperviseur défaillant vers un nœud opérationnel, sans interruption perceptible pour les utilisateurs finaux. L'alimentation électrique de ces équipements est systématiquement secourue par une double adduction électrique ondulée, complétée par un groupe électrogène pour le datacenter principal.

Concernant la connectivité réseau des établissements scolaires, l'architecture prévoit une redondance des équipements de cœur de réseau (switchs et routeurs configurés en mode actif/actif ou stack). De plus, l'accès Internet des sites critiques fait l'objet d'une sécurisation par diversité de liens : la liaison principale (Fibre Optique) est doublée par une liaison de secours techniquement distincte (4G/5G ou lien cuivre DSL), configurée pour prendre le relais automatiquement via des protocoles de routage dynamique (SD-WAN ou failover) en cas de coupure physique du lien nominal.

Enfin, pour pallier une indisponibilité temporaire des services centraux, des mécanismes de continuité locale sont déployés. Les serveurs présents dans les écoles (pour les classes mobiles ou la mise en cache) sont configurés pour permettre une authentification locale temporaire et l'accès aux ressources pédagogiques déjà téléchargées, assurant ainsi un fonctionnement en mode dégradé même en cas de coupure du lien avec le centre de données municipal.

## 10.2 Reprise (PRA)

Le Plan de Reprise d'Activité (PRA) technique définit les moyens et procédures nécessaires pour reconstruire le système d'information suite à un sinistre majeur (incendie du datacenter, inondation, attaque par rançongiciel destructif) ayant rendu les mécanismes de haute disponibilité inopérants.

La stratégie de reprise repose sur la réplique asynchrone des données et des machines virtuelles critiques vers un site de repli techniquement étanche et géographiquement distant du site principal (site secondaire municipal ou hébergement Cloud souverain certifié SecNumCloud). Cette réplique doit permettre de respecter les objectifs de reprise définis avec les métiers : un *Recovery Point Objective* (RPO) fixant la perte de données maximale admissible à 24 heures pour les données scolaires standards, et un *Recovery Time Objective* (RTO) visant un rétablissement des services essentiels (ENT, restauration scolaire, gestion administrative RH) sous 4 heures ouvrées après la décision de déclenchement du plan.

Pour garantir la capacité de reconstruction même en cas de compromission totale du réseau (scénario "Blackout"), l'équipe technique maintient un « Kit de Survie

Informatique » (Crash Kit). Ce dispositif comprend la documentation technique complète de l'architecture, les procédures de réinstallation "Bare Metal", les sources d'installation des systèmes d'exploitation et applications, ainsi que les identifiants d'administration de secours (comptes "Brise-glace"). Ces éléments sont stockés sur des supports chiffrés, déconnectés du réseau et conservés dans un coffre-fort ignifugé accessible uniquement au RSSI et à la Direction Technique.

Des tests de bascule technique sont réalisés annuellement sur un périmètre défini pour valider l'intégrité des données répliquées et l'efficacité des procédures de redémarrage, permettant ainsi d'ajuster les configurations et de maintenir le PRA en condition opérationnelle.

## 11. Sensibilisation

La sensibilisation à la sécurité des systèmes d'information s'appuie sur des dispositifs techniques simples et adaptés aux usages du secteur public, en complément des actions organisationnelles définies par la PSSI.

La DSNEP met à disposition des supports numériques de sensibilisation accessibles via les outils existants (ENT, intranet, messagerie) mis en place par l'équipe du RSSI en lien avec les RH, permettant la diffusion régulière de messages sur les bonnes pratiques de cybersécurité, notamment la gestion des mots de passe, la détection du phishing et la protection des données personnelles.

Des mécanismes techniques de prévention sont intégrés aux environnements numériques, tels que des avertissements lors de comportements à risque, des messages de sécurité dans les outils de messagerie et des blocages automatiques en cas de non-respect des règles de sécurité élémentaires.

Les outils de supervision et de journalisation permettent d'identifier les usages à risque récurrents et d'orienter les actions de sensibilisation ciblées. Les indicateurs issus de ces outils contribuent à l'amélioration continue des dispositifs de prévention.

Ces moyens techniques visent à renforcer progressivement la culture de cybersécurité des utilisateurs, tout en restant proportionnés aux contraintes et aux missions du service public éducatif.